

Lecture 3

Cyber Kill Chain



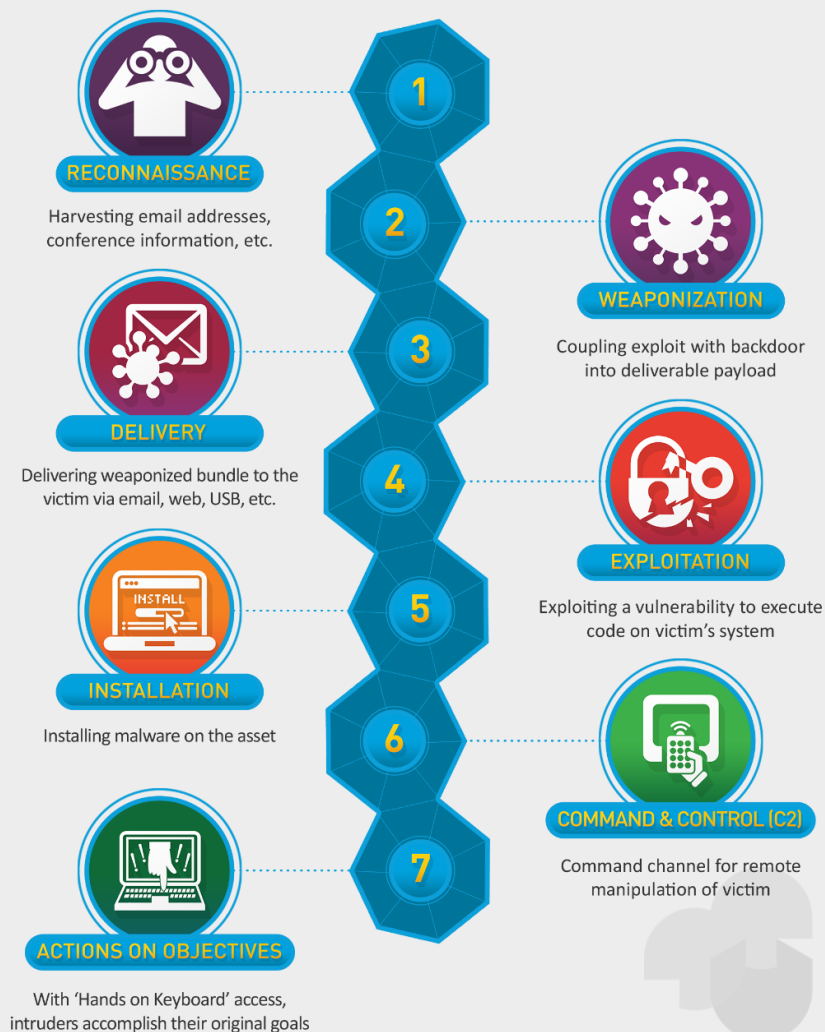
Outline

It includes:

- Introduction
- Cyber Kill Chain,

Cyber Kill Chain

- Framework that breaks down a cyber attack into seven stages.
- Developed by Lockheed Martin.
- Seven steps to enhance visibility into an attack.
- Enrich an analyst's understanding of an adversary's tactics.
- Interrupting an attack at any step of can meaningfully reduce the risk and impact of cyber threats.



Cyber Kill Chain: Reconnaissance

- Reconnaissance
 - Attackers gather information about their target to identify vulnerabilities and potential entry points.
 - This stage involves:
 - Collecting public data (e.g., websites, social media, WHOIS, network scanning).
 - Deploying spying tools.
 - Types:
 - Passive (OSINT)
 - Active (port scans, vulnerability probing)

Cyber Kill Chain: Weaponization

- Weaponization
 - Attackers pairs an exploit with a delivery mechanism (malicious doc, malware, ransomware, virus or worm) that can exploit a known vulnerability.
 - Attackers may also set up back doors so that they can continue to access to the system if their original point of entry is identified and closed by network administrators.
 - Payload is customized for the target environment (OS, apps, user roles)
 - Techniques:
 - obfuscation,
 - packing,
 - encryption,
 - staging (dropper → payload)

Cyber Kill Chain: Delivery

- Delivery
 - The attacker delivers the weaponized payload to the target.
 - Common vectors:
 - email attachments,
 - malicious links,
 - USB drives,
 - compromised websites.
 - Spear-phishing and social engineering are widely used.

Cyber Kill Chain: Exploitation

- Exploitation
 - The delivered payload or action is executed and a vulnerability is exploited.
 - The phrase “zero day” refers to the exploit code used in just this step.
 - They move laterally across systems, identifying more potential entry points and weaknesses.
 - Attacker Acquire or develop zero-day exploit.
 - Victim triggered exploits
 - Opening attachment of malicious email
 - Clicking malicious link
 - Attacker triggered exploits for server-based vulnerabilities.
 - Results: code execution, privilege escalation, or initial foothold

Cyber Kill Chain: Installation

- Attacker creates a persistent foothold so access survives reboots
- Common mechanisms:
 - services/daemons, scheduled tasks, registry autoruns, startup folders
- Advanced:
 - DLL side-loading,
 - WMI,
 - systemd units,
 - SSH key planting,
 - firmware/boot persistence

Cyber Kill Chain: Command and control

- Attackers establish a command and control (C2) channel to remotely monitor and guide their deployed cyberweapons.
- They use obfuscation to cover their tracks and DoS tactics to distract security teams from the core objectives of the attack.
- Channels: HTTP(S), DNS tunneling, WebSockets, email, custom TCP/UDP, peer-to-peer
- Techniques: beaconing, encrypted tunnels, domain fronting, fast-flux, covert channels
- Goal: remote control, tasking, and data transfer while avoiding detection

Cyber Kill Chain: Action

- The final phase involves executing the attack's primary objective, such as:
 - data theft,
 - sabotage,
 - financial gain, or
 - persistence expansion
- Typical activities:
 - Data exfiltration,
 - Privilege escalation,
 - Lateral movement,
 - Ransomware deployment.
- May be targeted (IP theft) or opportunistic (credential harvesting)